

Криптоанализ: Как раскрываются тайны

Криптоанализ ищет слабые места там, где их не предусмотрел разработчик.

Принцип Керкгоффа: алгоритм всегда известен



Безопасность системы должна зависеть только от секретности ключа, а не от сокрытия самого метода шифрования.

Иерархия атак по уровню сложности



Аналитик проходит путь от простого перехвата зашифрованных данных до возможности самому подсовывать текст для шифрования.

Побочные каналы: физика против кода

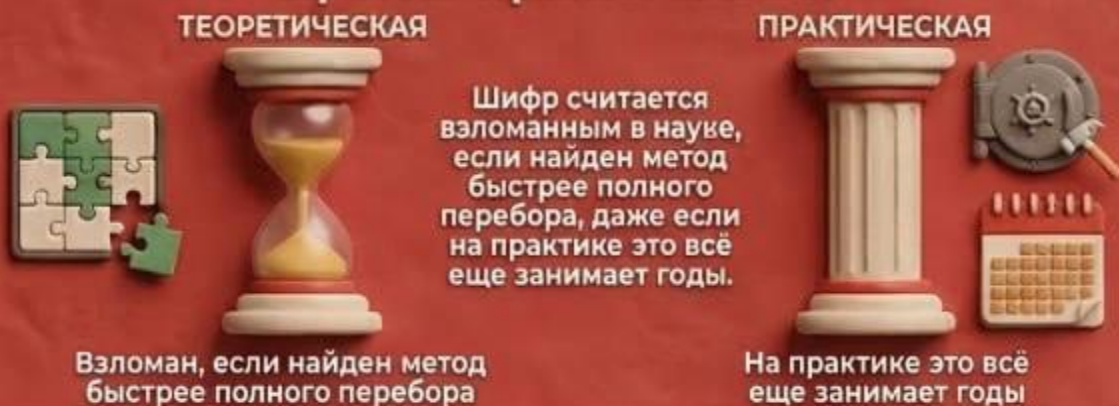


Информацию можно украсть, анализируя потребление энергии, шум процессора, время вычислений или даже свет от монитора.

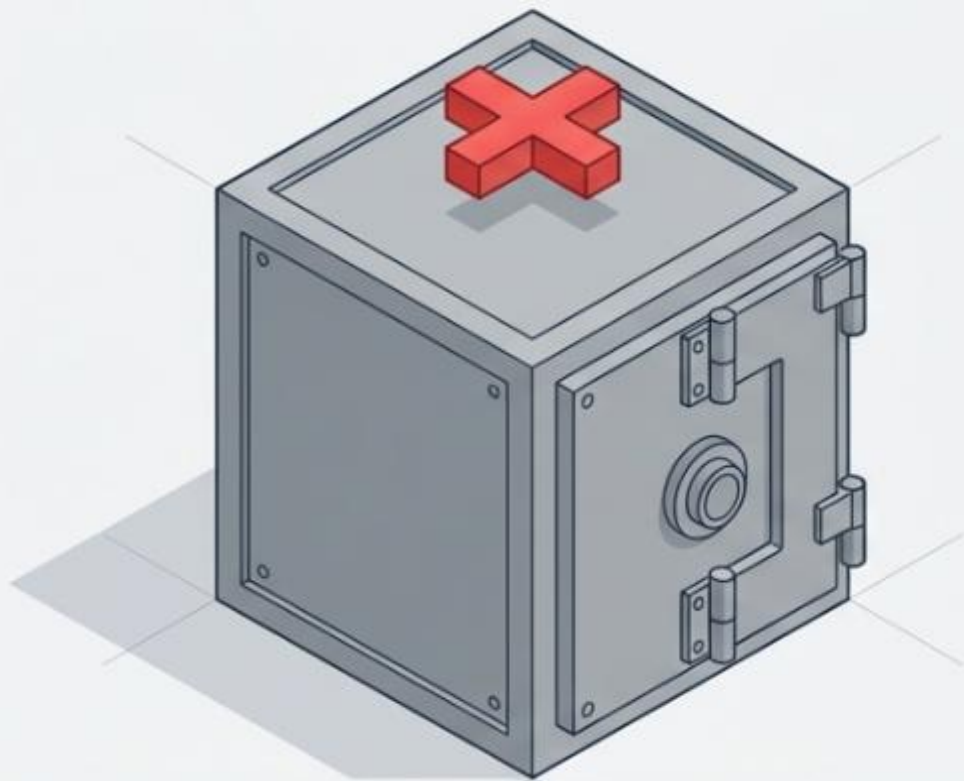
Градации успеха от догадки до взлома



Теоретическая стойкость против практической

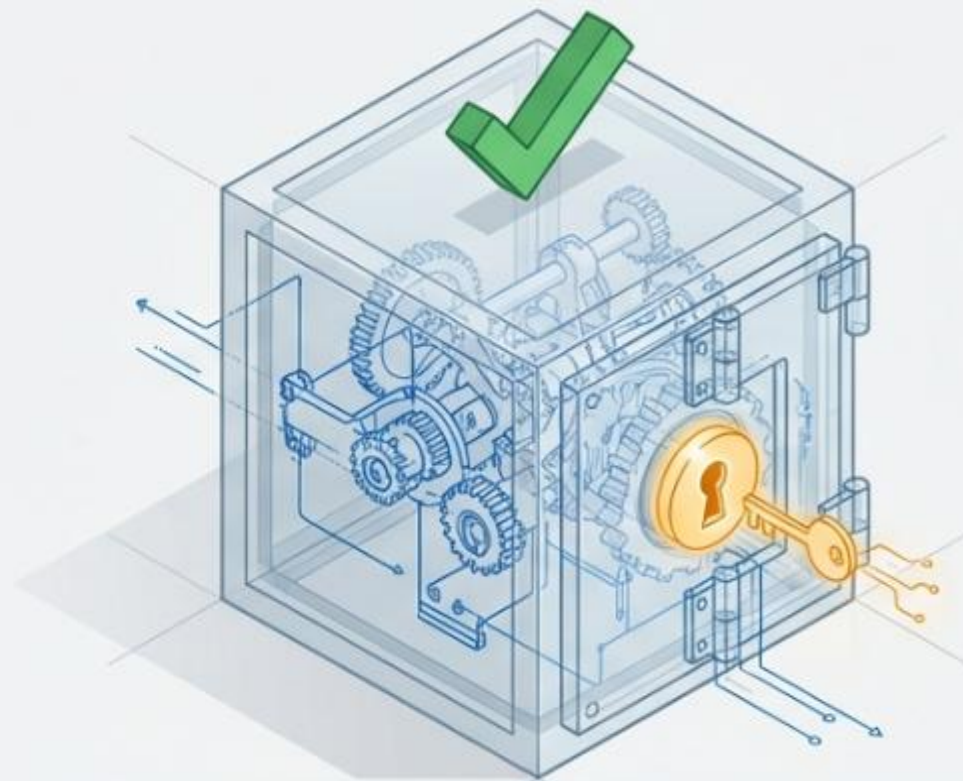


Что такое криптоанализ?



Ошибочный подход (Security through obscurity)

Скрытие алгоритма разработчиками. Реверс-инжиниринг программного кода занимает всего несколько дней.



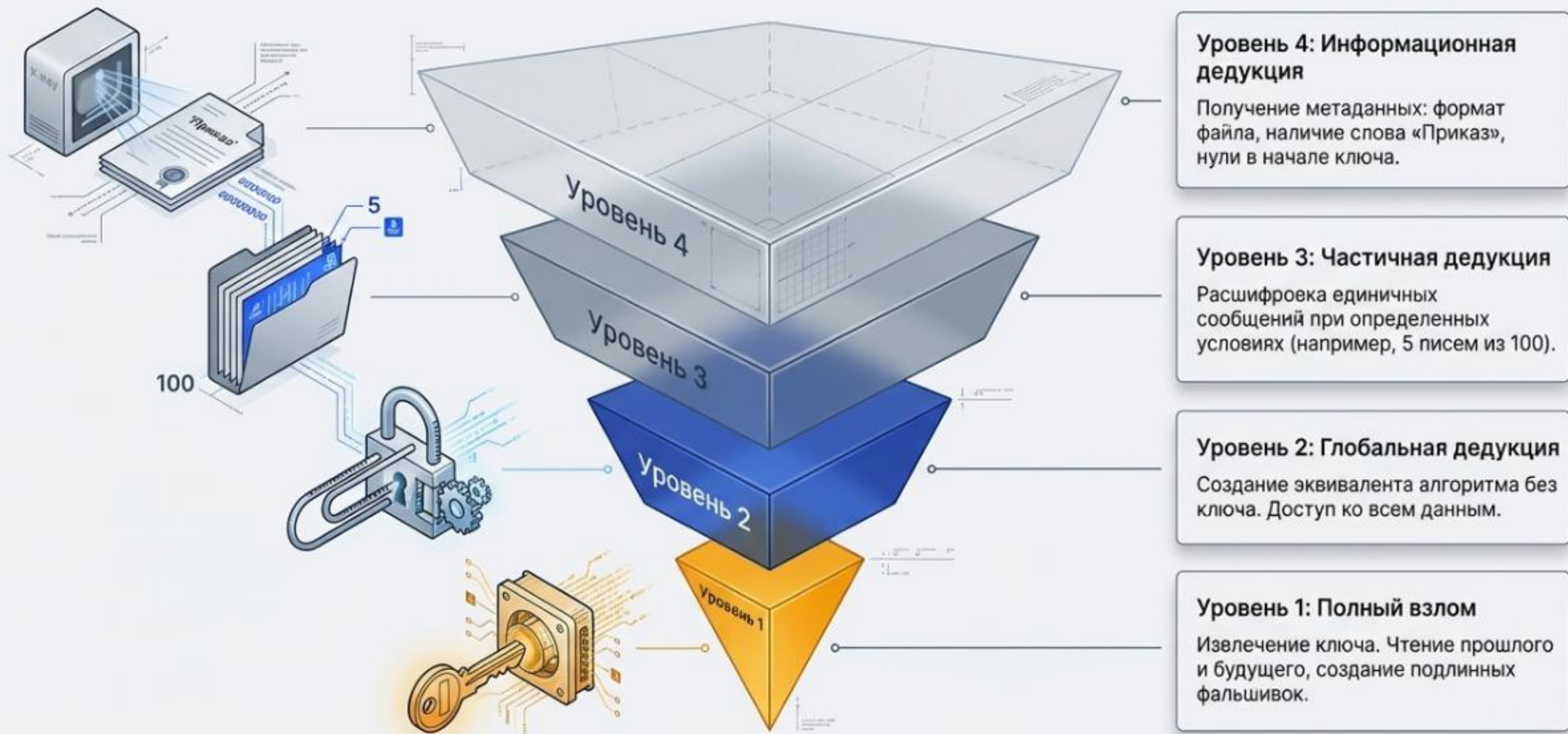
Принцип Керкгоффса

Секретность сообщения должна зависеть исключительно от ключа. Весь механизм шифрования известен противнику.

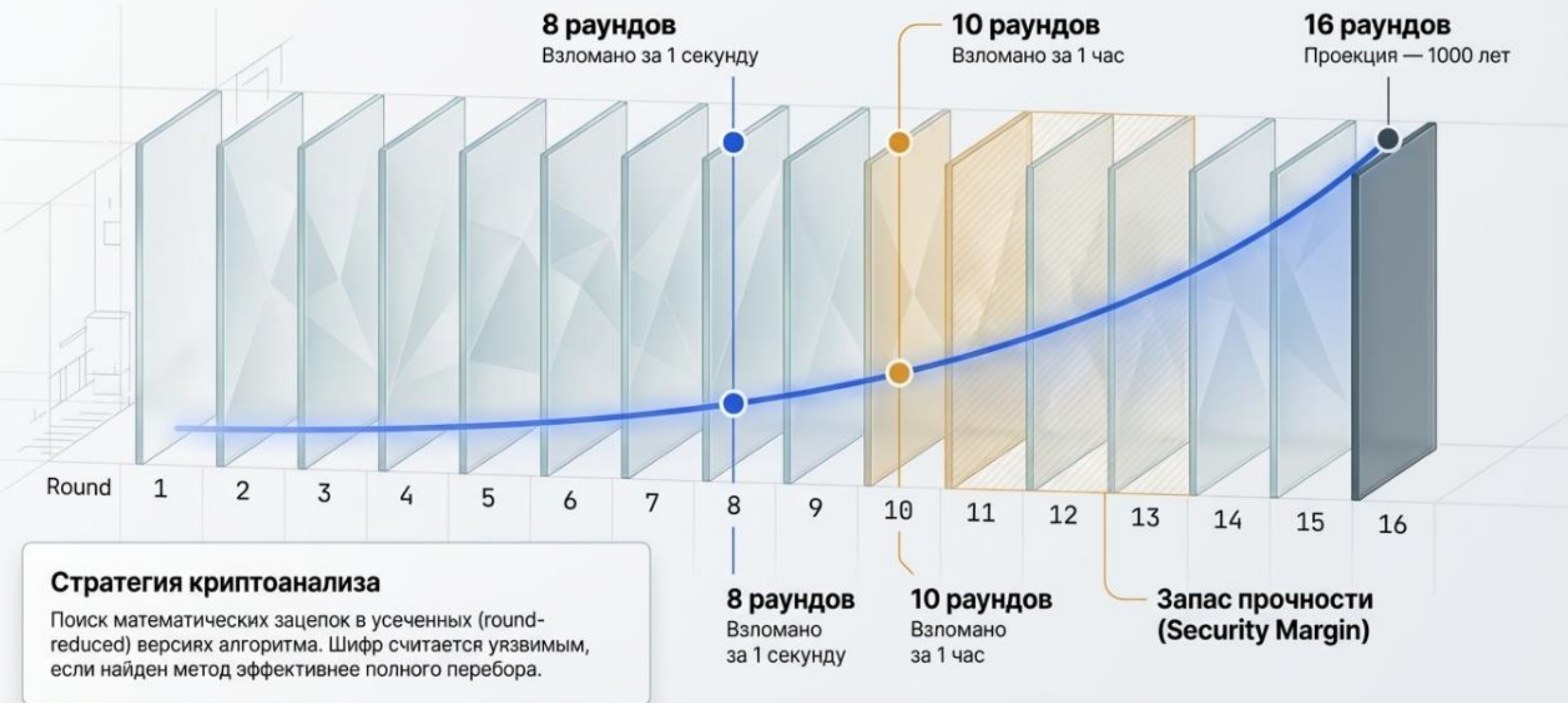
Криптоанализ — наука восстановления открытого текста или ключа без легального доступа к нему, а также выявление уязвимостей алгоритмов.

Анатомия взлома

Классификация исходов криптоанализа блочных шифров (по Ларсу Кнудсену)



Научный метод: От простого к сложному



Атака на основе шифртекста (Ciphertext-only attack)

Дано: Только перехваченный зашифрованный текст Y .



Расстояние единственности Шеннона

Минимальный объем перехваченного шифртекста, при котором существует только один правильный ключ.

Информационная избыточность

Знание стандартных заголовков файлов (magic bytes) и структур протоколов делает атаку разрушительной.

Статистические смещения

Поиск математических корреляций между битами в потоке.

Атака на основе открытых текстов (Known-plaintext attack)

Дано: Массив пар Открытый текст (P) + Шифртекст (C).

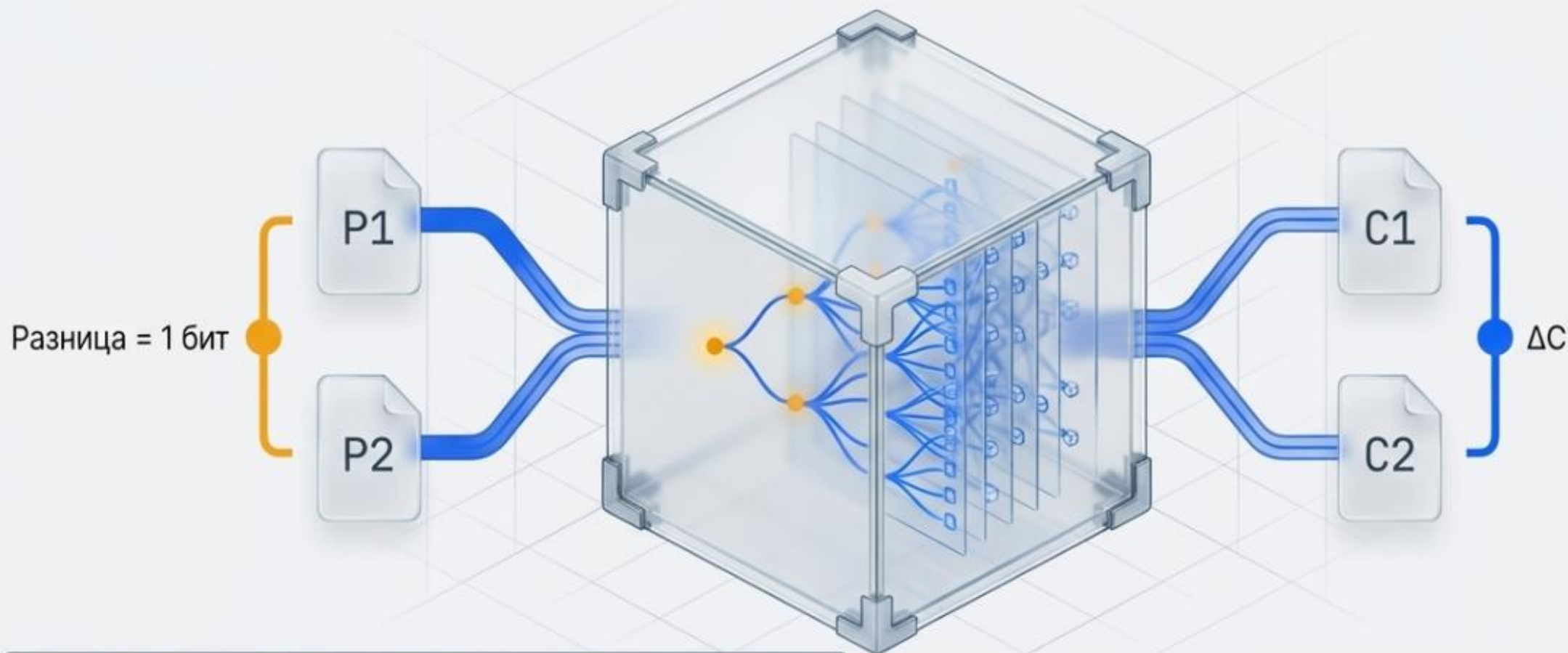


Стандарт FIPS: Вычислительная неотличимость

Шифр надежен только тогда, когда знание огромного массива пар P и C не дает никакой информации о ключе (шифртекст неотличим от шума).

Атака на основе подобранных текста (CPA)

Дано: Доступ к «Оракулу» — возможность зашифровать любые тексты без знания ключа.



Дифференциальный анализ

Целенаправленный поиск пар текстов для отслеживания того, как контролируемая разница на входе распространяется лавиной по раундам шифра на выходе.

Адаптивная CPA (CPA2)

Следующий текст для шифрования выбирается на основе результата предыдущего. Ключевой вектор атак на RSA.

Адаптивные и активные атаки

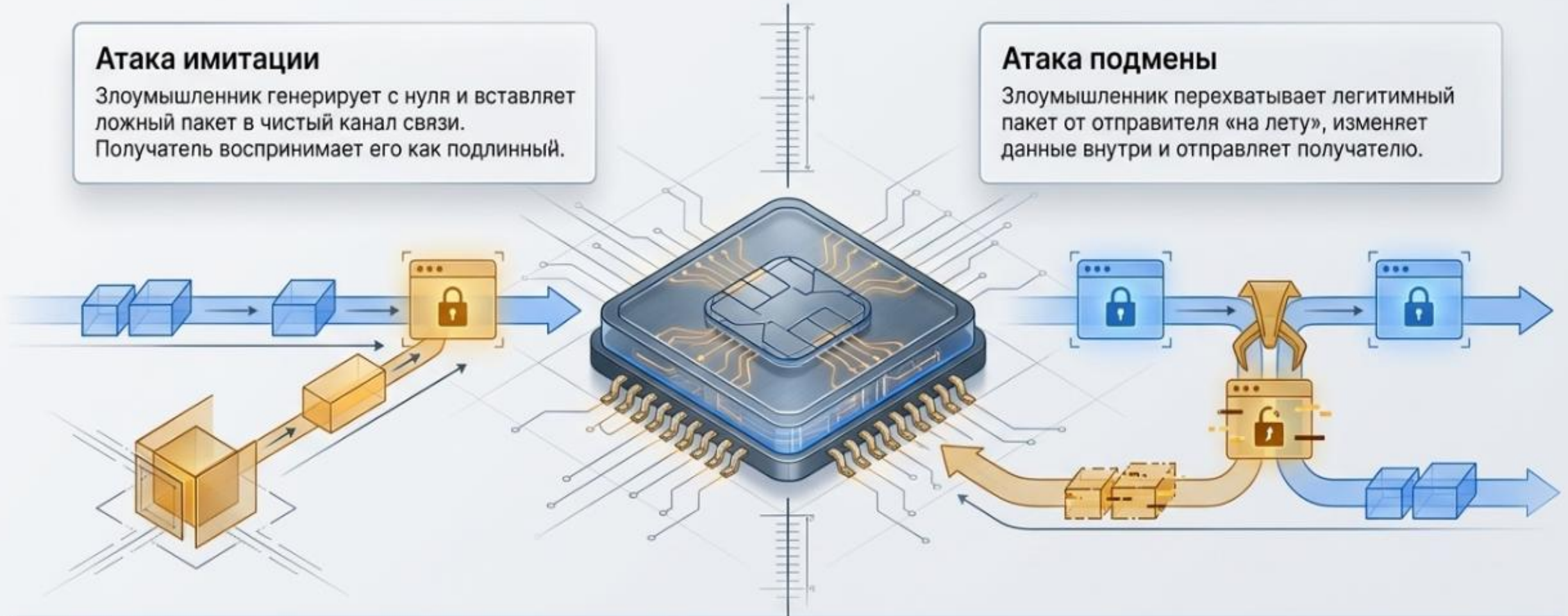
Выход в реальный мир: манипуляция потоками данных.

Атака имитации

Злоумышленник генерирует с нуля и вставляет ложный пакет в чистый канал связи. Получатель воспринимает его как подлинный.

Атака подмены

Злоумышленник перехватывает легитимный пакет от отправителя «на лету», изменяет данные внутри и отправляет получателю.



Требование безопасности: Имитостойкость

Способность самого алгоритма противостоять навязыванию ложных данных.

Классификация шифров по степени стойкости

Пределы прочности криптоалгоритмов



Предположительно стойкие

ГОСТ, AES. Рабочие лошадки современности. Базируются на текущем отсутствии методов быстрого взлома.



Доказуемо стойкие

RSA, DH. Безопасность базируется на нерешенных сложных математических задачах (например, факторизация).



Безусловно стойкие

Шифр Вернама. Математически нераскрываемы при любом объеме перехвата (ключ = размер текста). Непрактичны.



Проблема современной криптографии

Отсутствие доказанной нижней границы стойкости. Длина ключа задает лишь объем пространства, но вероятность угадать ключ существует всегда.

Частотный анализ: Фундамент криптоанализа

Исторические корни и статистика естественного языка.



ХШМПВ ОФЭЦЫ ЛЮТЯБ ЫПДКА
ЕРГЖИ МНТЩД ФХСБЮ ЛКЗЕЯ
ТЦАШО ЭПДЖВ РБЫСН ЛТМКЩ
ИФЯЗХ ПДЮСБ ЕОФЖГ ЯТШКЫ
ЛДМНТ ЦХРБИ ЭПЗСЮ АЖОФБ
АЖОФБ ТДМШП НКЭИР ЛСЮАЩ
БОЗЦЖ ЕРФТД ЕРФТД НКЯСЮ
ПХШЫБ ЛДЭТМ ЖИРЦФ ЖИРЦФ
ТЯСНП БОЭШЫ АФЗХЛ БЭХЛ
ИЭЮРЦ БПТМЯ ГФОЖС
ПНЭТД АЯРЛЩ БХМСФ
НТЯСЮ ЗОЭШИ БЦРГД...

Статистические аномалии языка

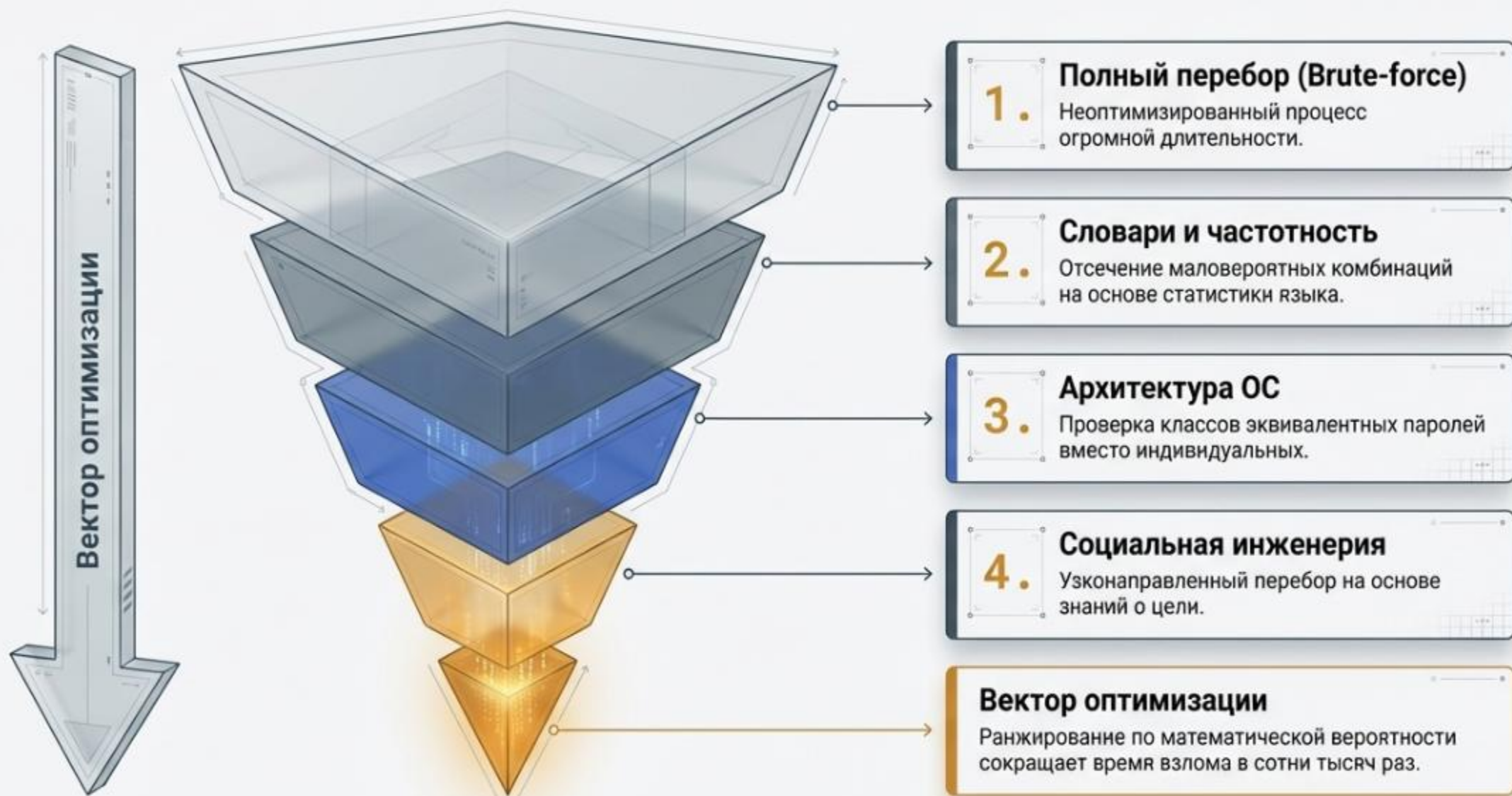
Частотный анализ использует вероятности и лингвистические правила (например, пара «ср» вероятна, а «оь» не существует).

Современное требование

Шифртекст должен иметь идеально равномерное распределение символов, чтобы исключить статистические гипотезы.

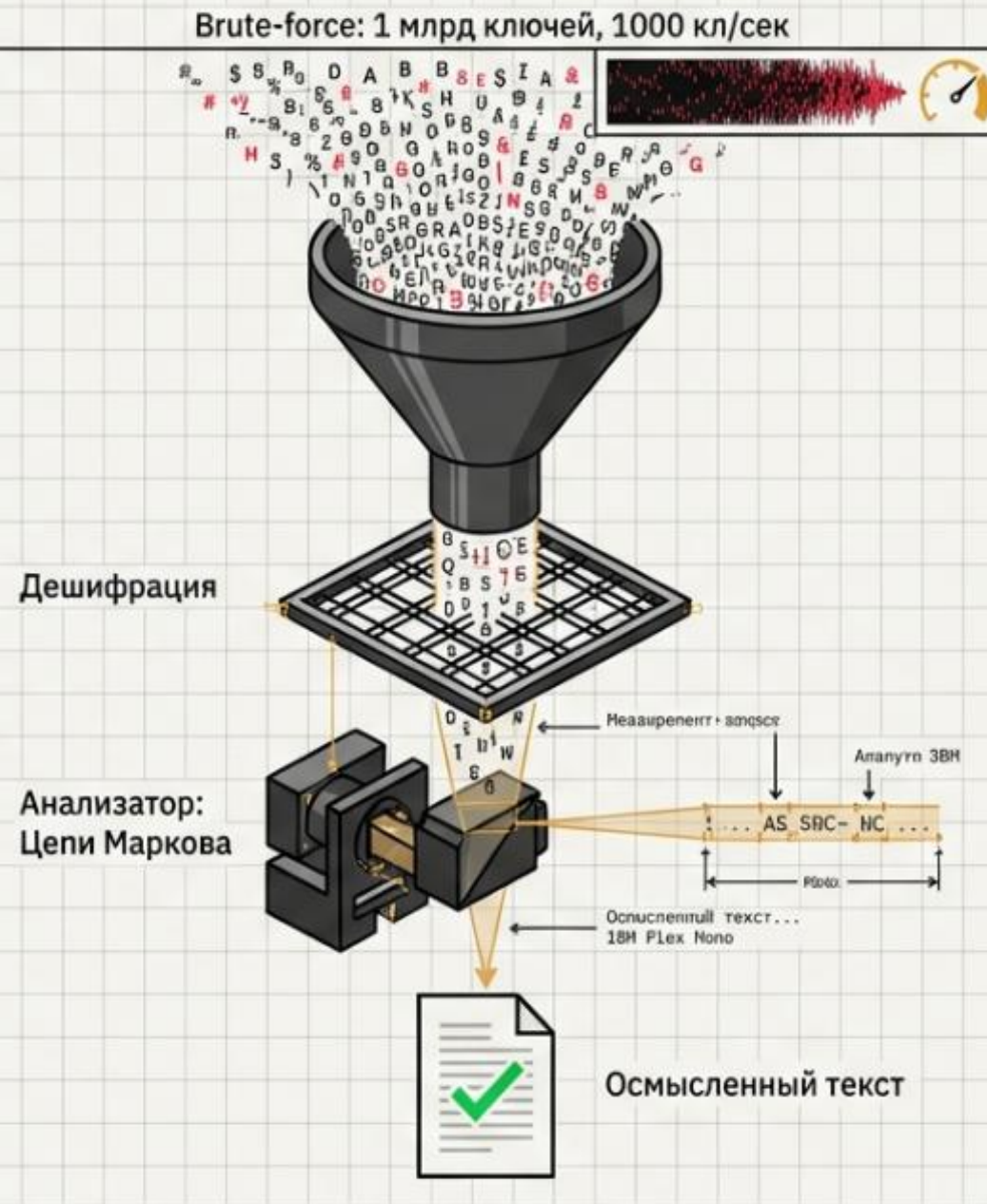
Эволюция подбора паролей

От грубой силы к умному вектору. Прикладное применение статистики.



Универсальные методы: сито полного перебора

- Проблема: Оценить «осмысленность» выходных данных графического файла или программы крайне сложно.
- Решение: Для текстов используются цепи Маркова. Они работают как математическое сито, позволяя ЭВМ автоматически распознавать правильный текст среди миллионов случайных символов без участия человека.



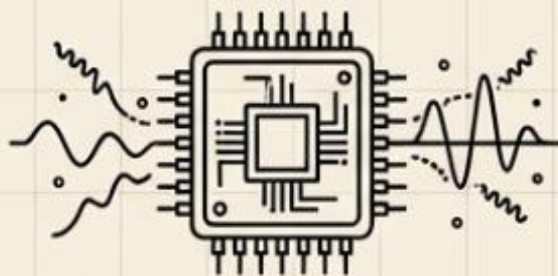
Фундаментальная уязвимость: проблема генерации ключей

Слабые программные ГСЧ



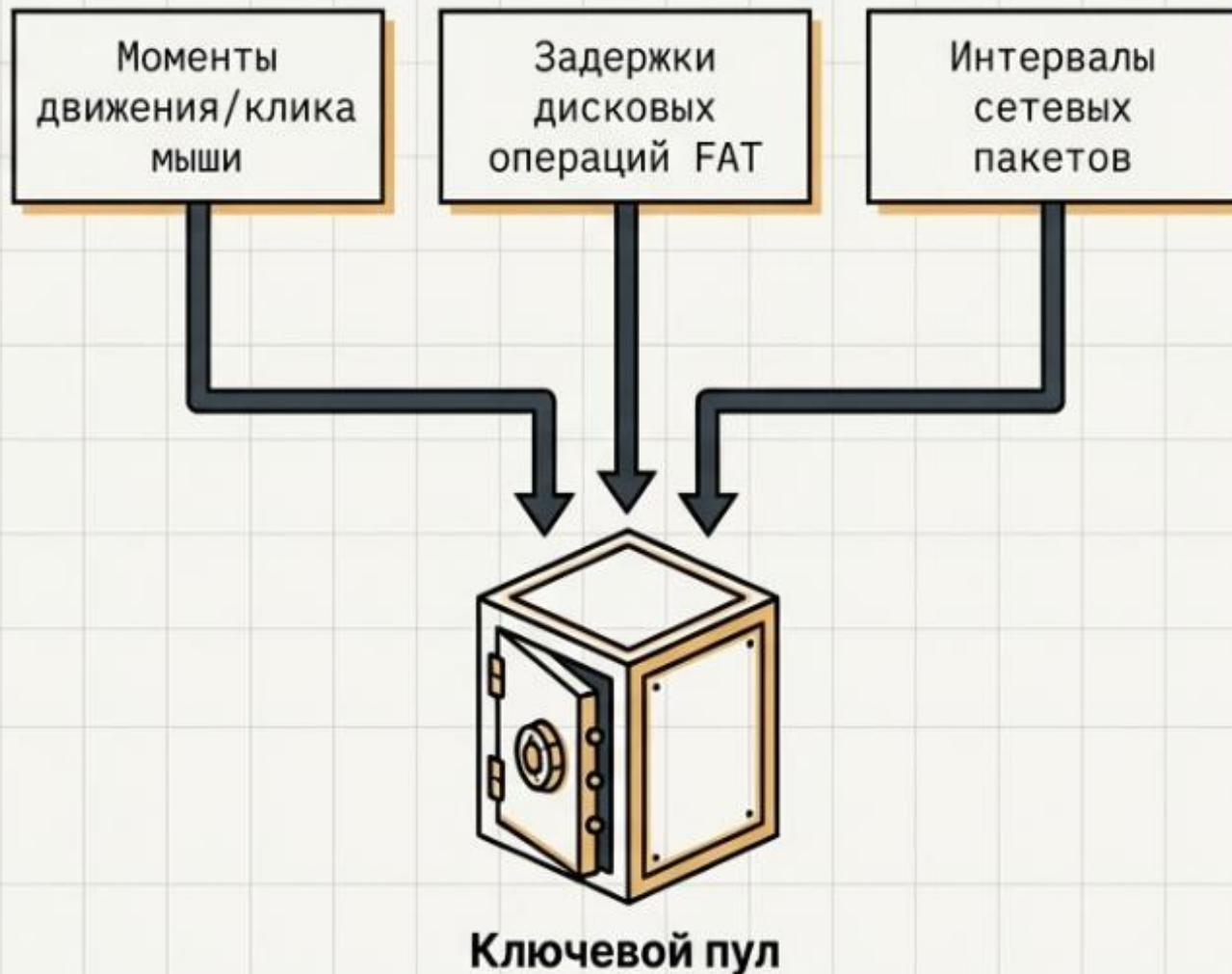
Слабые ключи: псевдослучайные числа на основе времени или ввода. Делают шифр AES-256 бесполезным из-за предсказуемости.

Истинная энтропия (Аппаратные ГСЧ)



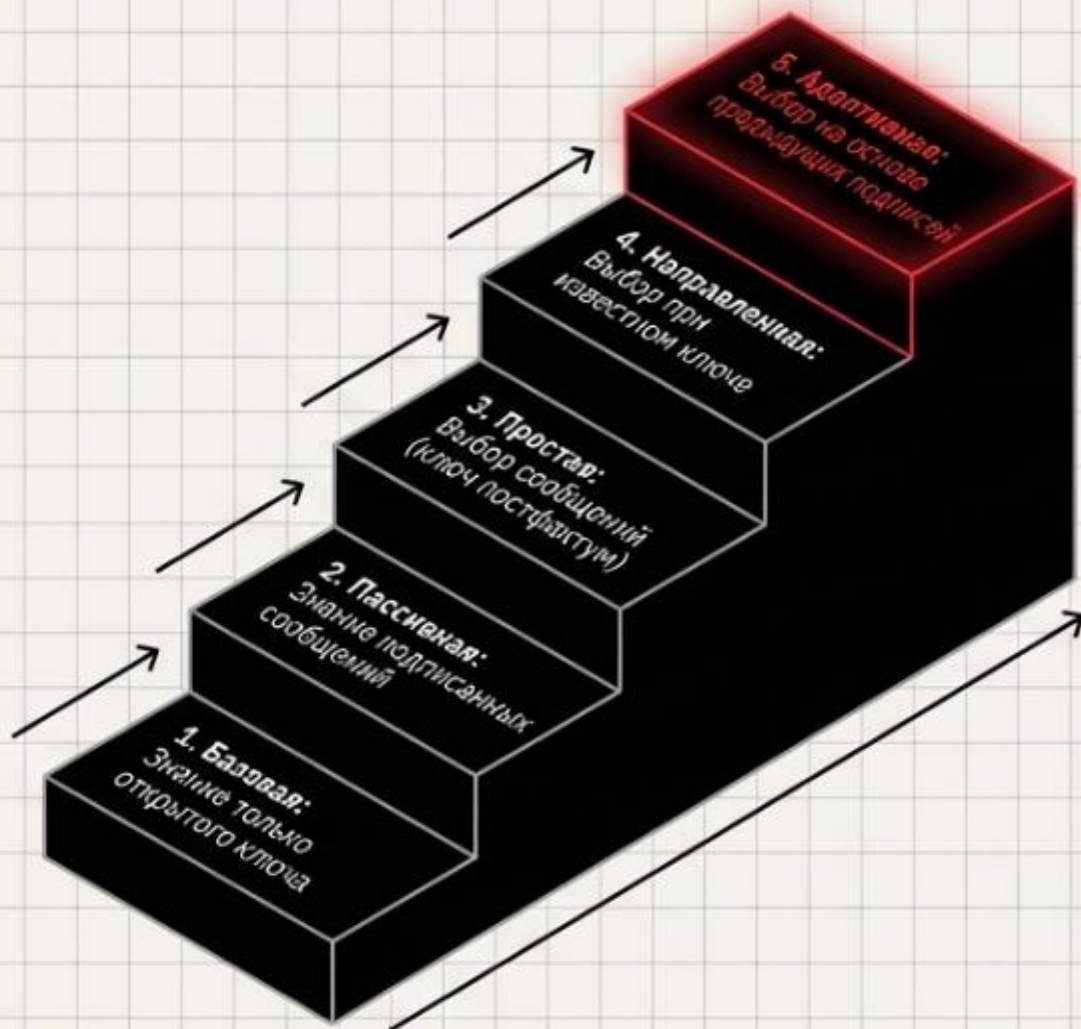
Истинная энтропия: использование физического шума оборудования.

Источники энтропии по Брюсу Шнайеру



Атаки на ЭЦП и уязвимости хэш-функций

Шкала угроз для ЭЦП



Оригинал



Подделка



Хэш-функция

0x9F7B2A1E4D5C3B8A9F7B2A1E4D5C3B8A

Одинаковый хэш



Цифровая
подпись



Метод коллизий: позволяет злоумышленнику подделать документ, сохраняя валидность оригинальной ЭЦП.

Механика поточных шифров: «Криптографический конструктор»



Синхронные шифры

- Ключевое свойство: Отсутствие эффекта размножения ошибок.
- **Риск:** Противник может производить управляемые изменения шифртекста.

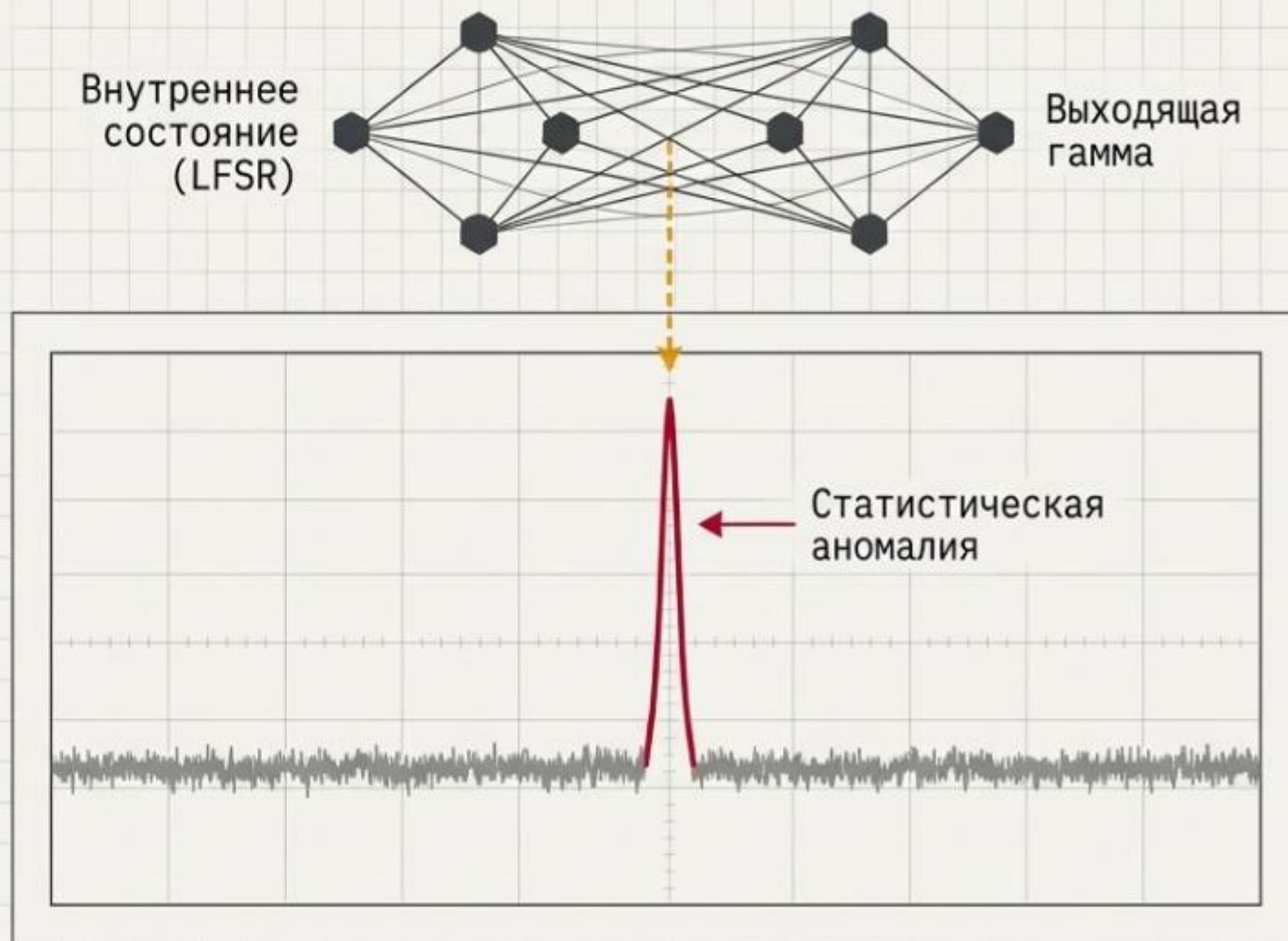
Самосинхронизирующиеся шифры

- Ключевое свойство: Автоматическое восстановление при потере связи.
- Применение: Стандарт для военных и дипломатических систем.

Особенность: Работают побитово, требуют меньше кода и выполняются быстрее блочных шифров (8-16 действий на байт).

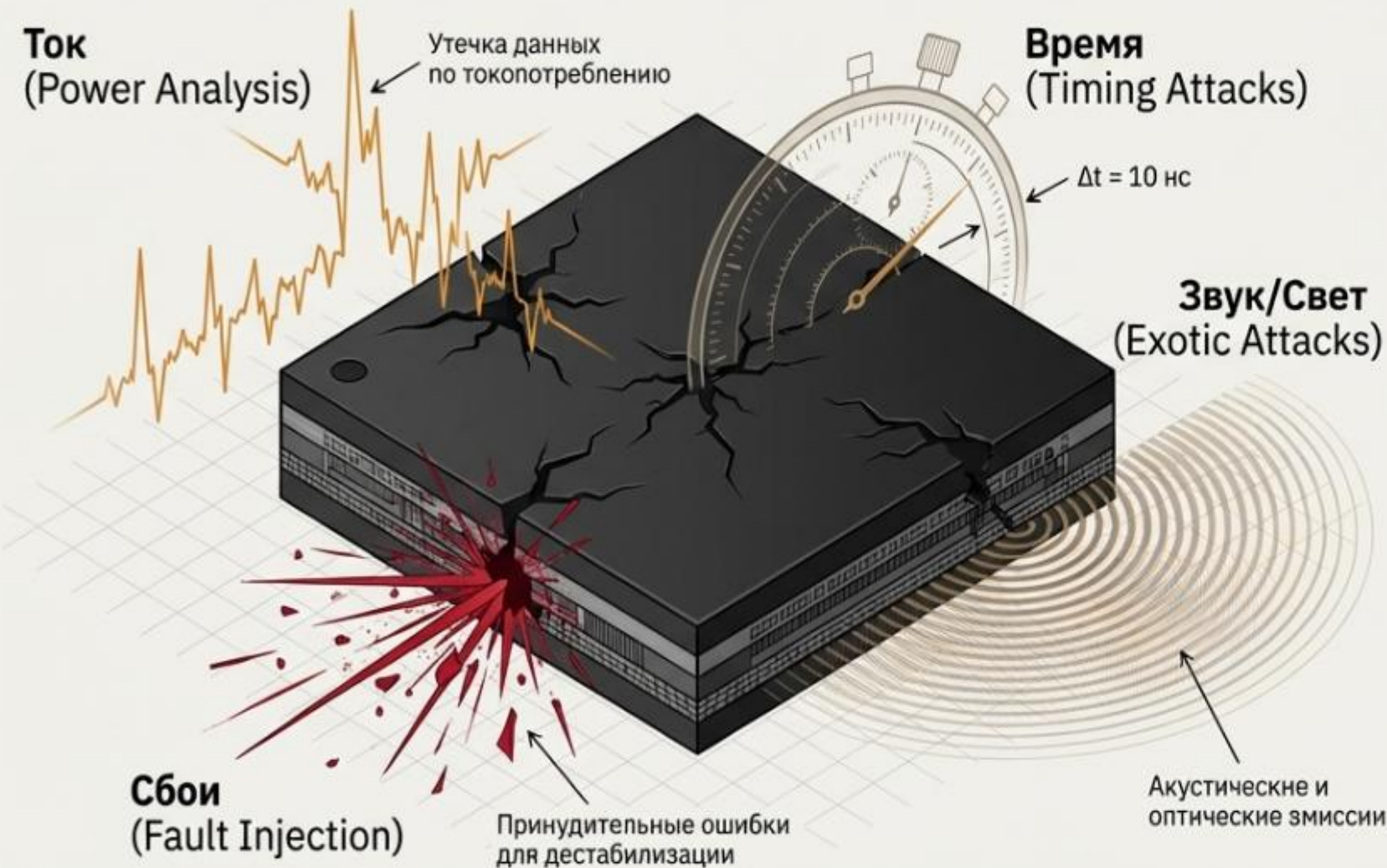
Взлом поточных шифров: Корреляционные атаки и линеаризация

- **Проблема малого периода:** Если ключ начинает повторяться, злоумышленник использует открытые части для дешифрации остального текста.
- **Корреляционная атака:** Поиск статистической связи между внутренней последовательностью (регистром сдвига) и итоговой гаммой.
- **Методология взлома:** Сведение задачи поиска ключа к решению системы линейных уравнений или использованию статистических пиков.



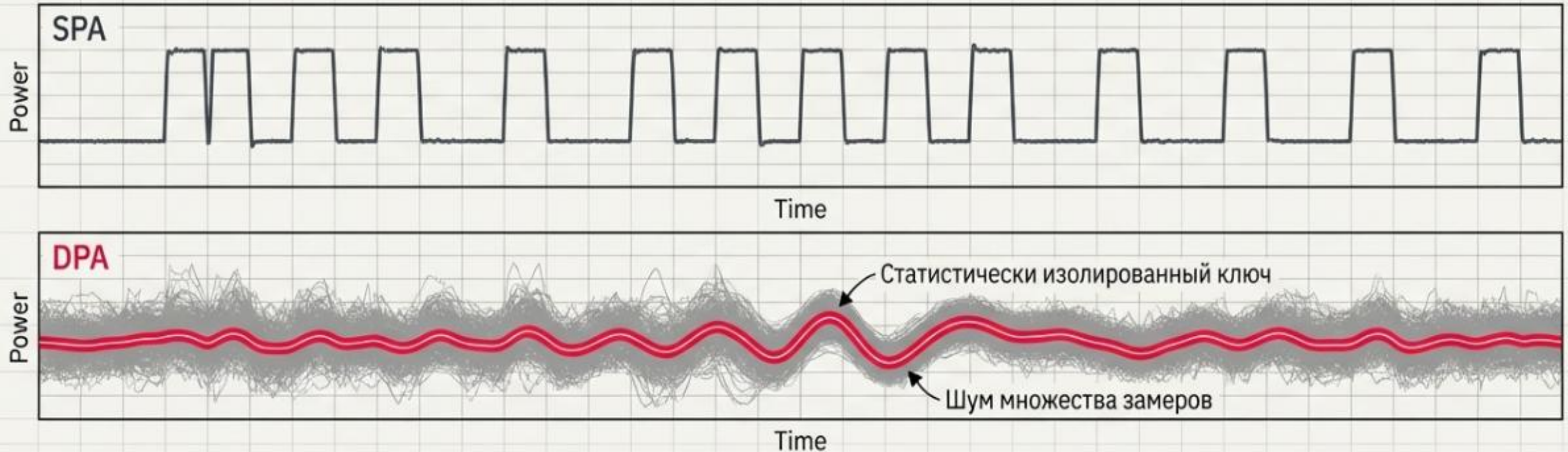
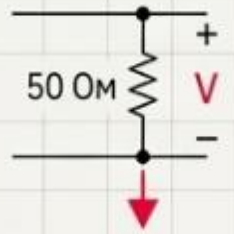
Смена парадигмы: Атаки по побочным каналам

Сегодня ломают не математику, а физическую реализацию шифра. Атаки используют информацию физической среды, превосходя классический криптоанализ на порядки.



Классификация атак:	
Категория	Типы Атак
Контроль	Пассивные (Наблюдение)
	Активные (Манипуляция)
Доступ	Агрессивные (Разрушение)
	Полуагрессивные (Обратимые)
	Неагрессивные (Без следов)
Анализ	Простые (SSCA) (Одна трасса)
	Разностные (DSCA) (Множество трасс)

Утечки физического уровня: Анализ мощности и времени



SPA (Simple Power Analysis): Прямое чтение выполняемых инструкций процессора. Занимает секунды.

DPA (Differential Power Analysis): Статистическое выделение скрытого ключа из множества замеров. Занимает часы, но не требует знаний о реализации устройства.

Тайминг-атаки: Измерение времени вычислений выдает точное значение экспоненты в Diffie-Hellman.

Оборудование: Подключение резистора на **50 Ом** к цепи питания позволяет измерять напряжение на частотах >1 ГГц с ошибкой $<1\%$.

Активное вмешательство: Атаки по ошибкам вычислений (Fault Attacks)



Внедрение сбоя:

Искусственное создание аномальных условий вызывает кратковременный или постоянный сбой бита.

Разностный анализ:

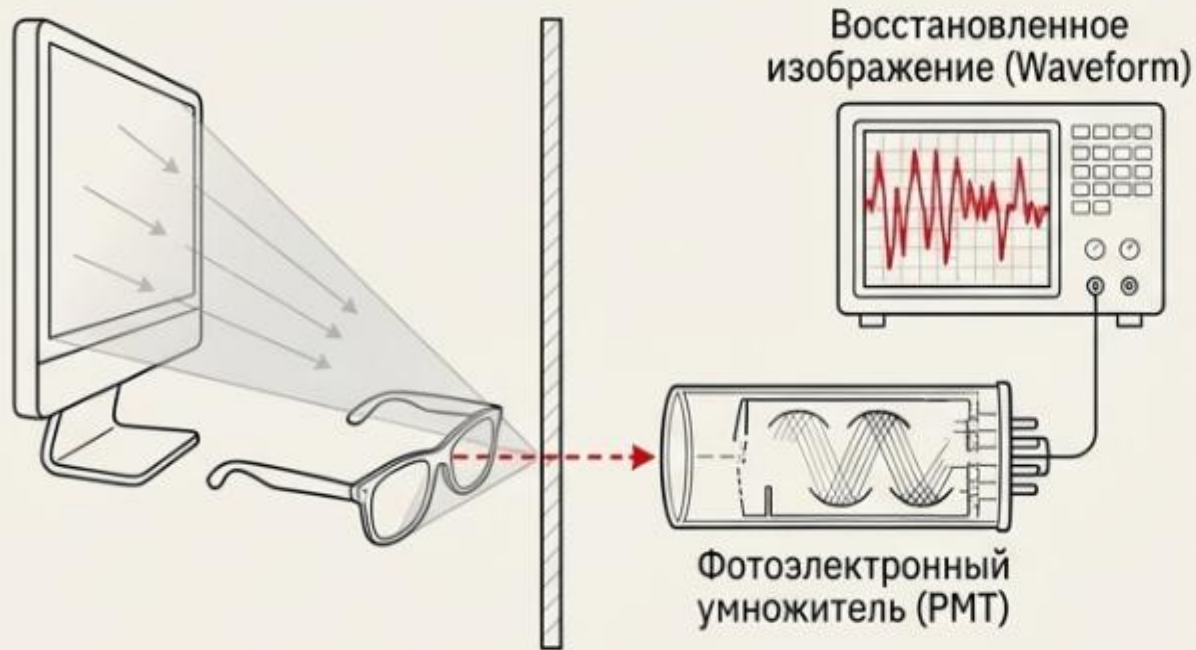
Сравнение нормального шифртекста с ошибочным при одинаковом открытом тексте восстанавливает ключ.

Уязвимости:

Успешно применяется против ГОСТ 28147-89, DES и RC5, особенно в смарт-картах.

Экзотические каналы: Предательство света и звука

Оптика: Атака Куна



Восстановление изображения экрана по отражению света от стен или очков. Модуляция светодиодов коррелирует с сигналом (Glowworm).

Акустика: Coil Whine



Писк дросселей и конденсаторов при тяжелых вычислениях (RSA). Ультразвуковые колебания обходят программные фильтры шума.

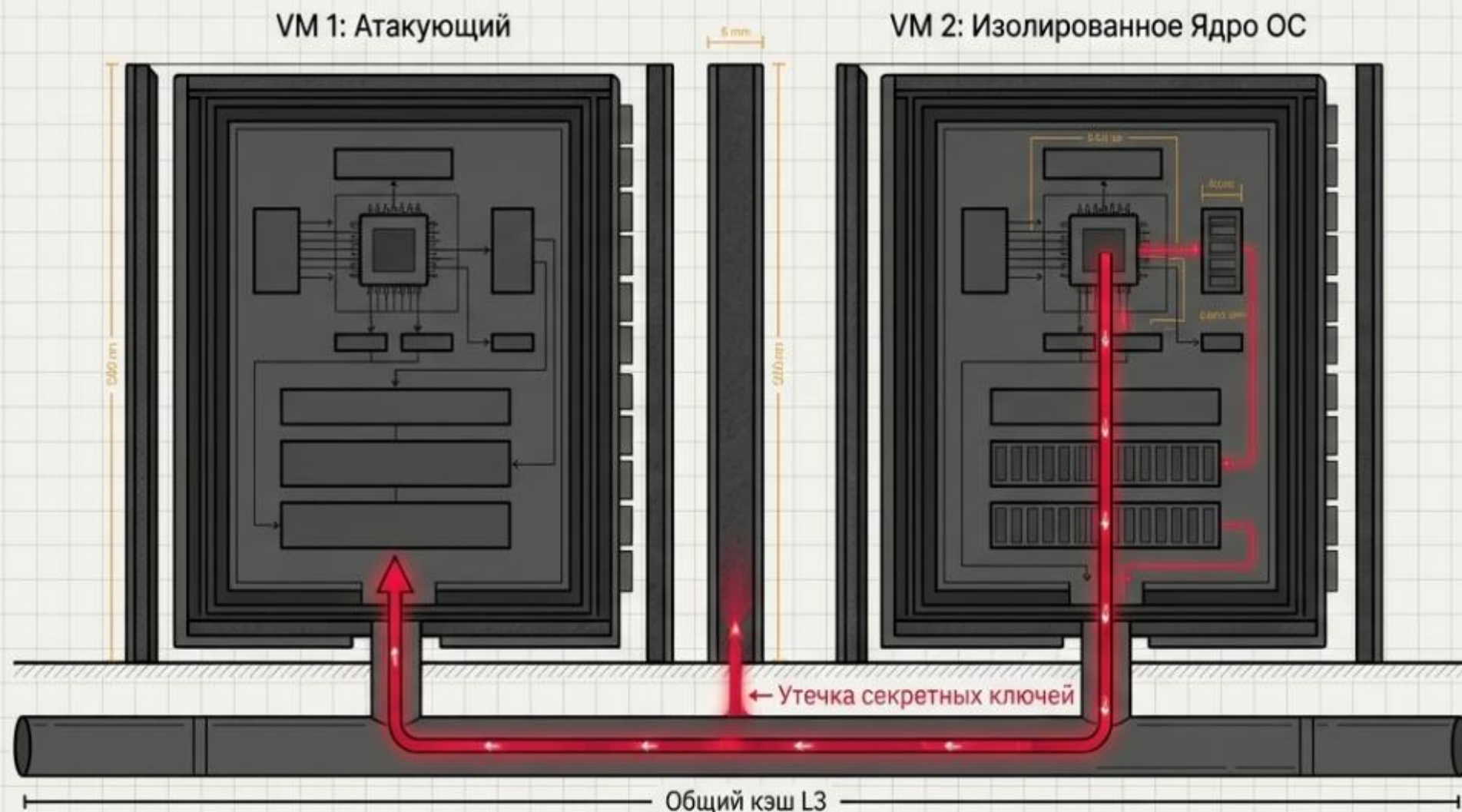
Акустика ввода: Анализ звука нажатия клавиш позволяет восстановить пароли с точностью до 95%.

Микроархитектурные атаки: Шпионаж через кэш L3 (Flush+Reload)

Механика слежки за соседним процессом через общую память.



Кульминация: Уязвимость Spectre и крах изоляции



Синтез угроз:

Атаки по времени и на кэш слились в фундаментальную угрозу аппаратного уровня.

Spectre эксплуатирует спекулятивные вычисления процессоров, позволяя красть данные прямо из изолированной памяти ядра ОС и соседних виртуальных машин.

Итог: Сегодня математически безупречный шифр бесполезен, если уязвима сама физическая и микроархитектурная среда его исполнения.

ОСНОВЫ КРИПТОГРАФИИ

Лекция № 1. Введение в криптографию

Основные понятия, терминология ГОСТ и цели защиты информации

→ Загрузить

Введение в криптографию: основные понятия, терминология ГОСТ и цели защиты информации

